

Manual 04 - NIST AI 600-1 Generative AI Profile Implementation

CONTROLLED PUBLICATION QA CANDIDATE

Controlled source revision: 2b1e27f06c1f35ff2b95b8b528a30aae4682bd5d | Language: en | NIST AI 600-1 Generative AI Profile with AI RMF 1.0 parent framework; version-aware and source-watched.

Assurance boundary: This voluntary implementation manual does not certify a GAI system, establish legal compliance, prove trustworthy-AI achievement, or provide an audit opinion; not every suggested action applies to every actor, system, use case, or lifecycle context.

Implementation paths and operating model

Manual 04 implementation paths

Purpose and control boundary

This intake converts NIST AI 600-1 into scalable implementation work without turning voluntary suggested actions into universal requirements. Every organization must determine applicability from its GAI inventory, AI actor tasks, lifecycle stage, context of use, affected parties, risk tolerance, applicable obligations, and resources.

The three paths change the depth, independence, frequency, and evidence expected. They do not change the need to understand material GAI risk, assign accountable decisions, stop or rollback unacceptable use, respond to incidents, and retain defensible evidence.

1. Select a proportionate path

Essential path

Use when the GAI footprint is narrow, the organization is small, use cases are low-complexity, and no material safety, rights, critical-service, highly sensitive data, high-capability, or large-scale public-information impact has been identified.

Minimum operating set:

- named executive or owner for GAI risk;
- inventory of approved models, services, integrations, use cases, users, and data;
- acceptable-use and prohibited-use rules;
- screening of all twelve GAI risk families;
- basic privacy, security, intellectual-property, content, and supplier checks;
- documented human review for consequential outputs;
- defined release, stop, rollback, and incident-escalation criteria;
- periodic monitoring and reassessment after material change; and
- one evidence register linking decisions, tests, findings, remediation, and residual risk.

Structured path

Use when multiple GAI systems or business units are involved, sensitive data or regulated processes are present, customer-facing outputs are material, third-party dependencies are significant, or the organization needs repeatable assurance.

Add to the Essential path:

- formal GAI governance forum and actor/responsibility map;
- action-by-action applicability and tailoring register;
- model/system/use-case/ecosystem risk assessments;
- risk-based pre-deployment TEVV and red-teaming plan;
- content-provenance and information-integrity controls;
- representative user and affected-party feedback;
- documented supplier due diligence, contract clauses, monitoring, and exit plans;

- independent review of higher-risk release decisions;
- defined metrics, thresholds, alerting, incident disclosure, and corrective-action workflow; and
- scheduled control-effectiveness review and management reporting.

Enhanced path

Use for high-capability or broadly deployed GAI, material national-security or CBRN exposure, safety-critical or essential-service contexts, high-impact decisions, vulnerable populations, large-scale information-integrity effects, high-value intellectual property, or complex value chains.

Add to the Structured path:

- independent technical and domain evaluation;
- adversarial testing against realistic threat models and misuse cases;
- controlled evaluation environments and protected test data;
- quantitative and qualitative uncertainty analysis;
- continuous monitoring for drift, capability changes, emergent misuse, and correlated failure;
- separation of development, validation, release, and residual-risk approval;
- rehearsed containment, model/service shutdown, fallback, and recovery procedures;
- enhanced downstream-use and ecosystem monitoring;
- formal affected-party, regulator, customer, and supplier communication plans; and
- board or equivalent oversight for risks exceeding delegated tolerance.

Manual 04 memory graphic 1

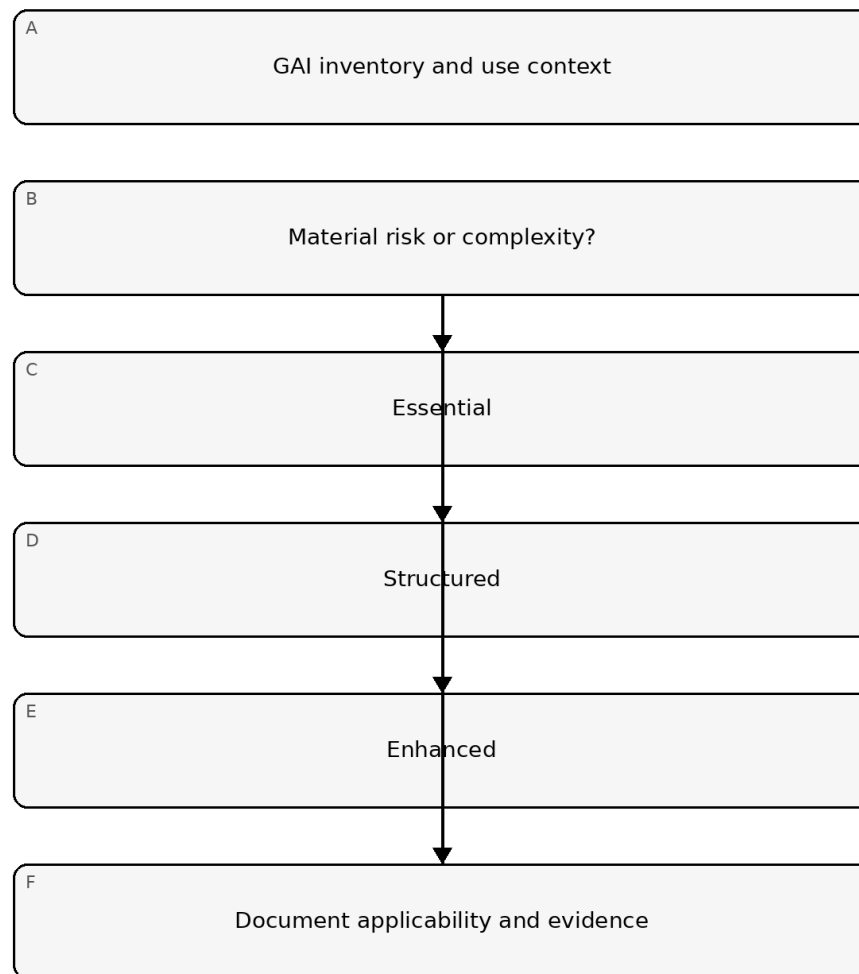


Figure 1. Implementation memory graphic

Accessible explanation: Start with the GAI inventory and actual context. Low, bounded uses may use Essential controls; multiple or sensitive uses need Structured controls; high-capability or high-impact uses need Enhanced controls. Every path ends in a documented applicability and evidence decision.

2. Operate the profile through the AI RMF Core

GOVERN

Establish the authority and conditions for using GAI:

- assign accountable owners and AI actor tasks;
- define risk tolerance, prohibited uses, acceptable use, escalation, and exceptions;
- integrate legal, privacy, security, safety, intellectual-property, records, procurement, and incident obligations;
- require competence and independence appropriate to the decision;
- define supplier, open-source, model, tool, plugin, retrieval, and downstream-use controls;
- protect whistleblowers and channels for reporting substantiated risk or harm;
- establish document retention, decision traceability, and change control; and
- require explicit approval before development, deployment, expansion, or material configuration change.

MAP

Describe the real system and context before measuring it:

- distinguish the base model, fine-tuning, retrieval, prompt/system instructions, tools, agents, application logic, user interface, and downstream consumers;
- identify intended purpose, reasonably foreseeable use and misuse, users, non-users, and affected parties;
- map data and content sources, rights, consent, sensitivity, provenance, transformations, retention, and deletion;
- map upstream providers, open-source components, APIs, hosting, monitoring, and fallback dependencies;
- assess risk at model, system, use-case, and ecosystem levels;
- record assumptions, limitations, uncertainty, benefits, negative impacts, and risk concentration; and
- determine which of the twelve GAI risk families are material, monitored, deferred, or not applicable, with reasons.

MEASURE

Use methods proportionate to the risk and claim:

- validate capability and performance claims under representative conditions;
- test confabulation, source/citation reliability, and uncertainty communication;
- evaluate privacy leakage, memorization, inference, and sensitive-data handling;
- test information security, prompt injection, data poisoning, model theft, tool misuse, and unsafe autonomy;
- evaluate harmful bias, homogenization, dangerous content, abusive content, and human-AI configuration;
- conduct risk-based CBRN and offensive-cyber capability assessment when relevant and authorized;
- assess content provenance, labeling, watermarking, metadata, detection limits, and chain of custody;
- evaluate intellectual-property and data-rights risks;
- measure resource and environmental impacts when material;
- use red-teaming, structured human feedback, field testing, or independent assessment as appropriate;
- record test scope, datasets, environment, thresholds, limitations, failures, and remediation; and
- include risks that cannot be measured quantitatively in the residual-risk decision rather than treating them as zero.

MANAGE

Turn evidence into accountable action:

- prioritize by context, likelihood or uncertainty, magnitude, scale, affected parties, reversibility, and organizational tolerance;
- select prevention, detection, response, recovery, transfer, avoidance, acceptance, or discontinuation treatments;
- define go, conditional-go, no-go, stop, rollback, containment, and decommissioning decisions;
- assign remediation owners and due dates;
- monitor model, system, use, supplier, data, content, and ecosystem changes;
- trigger reassessment after new capability, fine-tuning, retrieval change, tool access, deployment expansion, incident, supplier change, or regulatory change;
- disclose incidents to appropriate internal and external parties under applicable obligations;
- preserve evidence and communicate limitations to downstream actors and affected parties; and
- verify corrective action and feed lessons back into GOVERN and MAP.

Manual 04 memory graphic 2

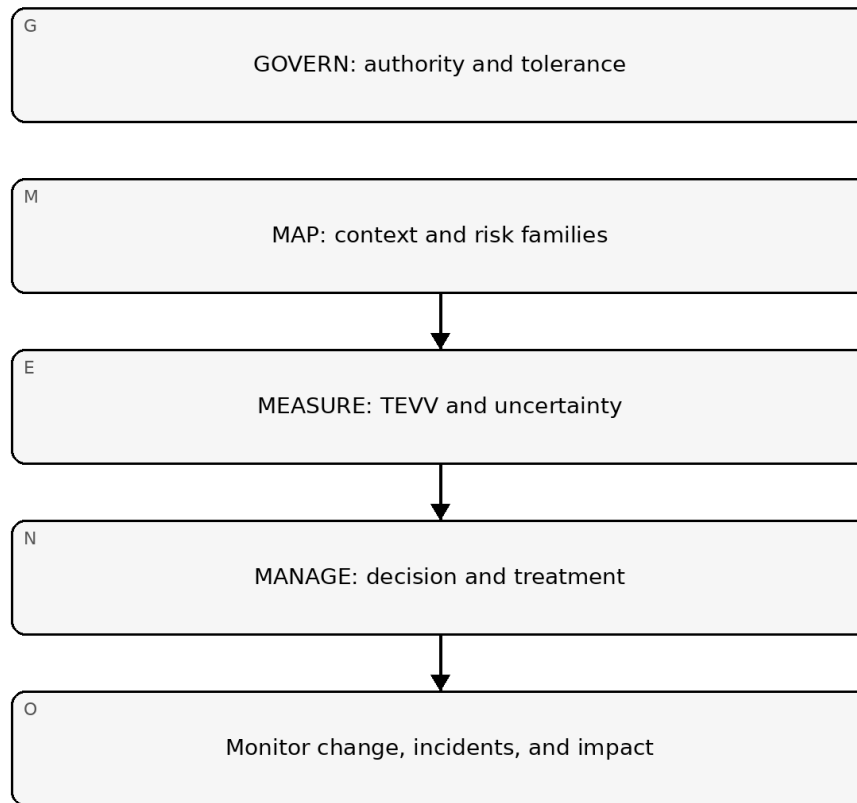


Figure 2. Implementation memory graphic

Accessible explanation: Governance sets authority and tolerance; mapping establishes context and relevant GAI risks; measurement produces test evidence and uncertainty; management makes and enforces decisions. Monitoring sends change, incident, and impact information back into governance.

3. Screen the twelve risk families

For each model, system, application, or use case, record a disposition for every family:

Risk family	Minimum implementation question	Example evidence
CBRN Information or Capabilities	Could the system materially lower barriers to harmful biological, chemical, radiological, or nuclear activity?	Authorized capability tests, access limits, escalation records
Confabulation	Could false or unsupported output cause material decisions, harm, or loss?	Grounding tests, citation checks, human-review thresholds
Dangerous, Violent, or Hateful Content	Can inputs or outputs facilitate violence, hate, extremism, or dangerous activity?	Safety evaluations, moderation results, misuse monitoring
Data Privacy	Can training, retrieval, prompts, logs, or outputs expose or infer sensitive data?	Data-flow map, privacy tests, retention and deletion evidence
Environmental Impacts	Are training or inference resource impacts material to the decision?	Energy/resource estimates, efficiency decisions, monitoring
Harmful Bias and Homogenization	Do outputs create disparate harms, correlated failure, or reduced diversity?	Subpopulation tests, affected-party feedback, mitigation results
Human-AI Configuration	Could users over-rely, misunderstand,	UX tests, instructions, workload and

Risk family	Minimum implementation question	Example evidence
	anthropomorphize, or lose effective oversight?	override evidence
Information Integrity	Can generated content undermine provenance, authenticity, public trust, or decisions?	Provenance design, labeling tests, disclosure and monitoring
Information Security	Can the system be attacked or misused through prompts, data, models, tools, APIs, or agents?	Threat model, red-team results, access and logging controls
Intellectual Property	Are training, input, output, or distribution rights uncertain or infringed?	Rights register, contract analysis, output review controls
Obscene, Degrading, and/or Abusive Content	Can the system create or amplify sexual, degrading, exploitative, or abusive content?	Safety tests, moderation, reporting and victim-support process
Value Chain and Component Integration	Can upstream or downstream dependencies create opaque, concentrated, or cascading risk?	Supplier inventory, contracts, change notices, fallback tests

No family may be omitted. Not applicable requires a recorded rationale and reconsideration trigger. A family may be material at one level and not another; for example, a base model risk may be controlled at the application layer, while ecosystem dependence remains.

4. Tailor suggested actions without losing accountability

Use an applicability register with these fields:

- NIST action ID and AI RMF subcategory;
- relevant GAI risk families;
- applicable AI actor tasks;
- model, system, use-case, and ecosystem scope;
- disposition: adopt, tailor, equivalent control, defer, or not applicable;
- rationale and requirement source;
- accountable owner and approving authority;
- implementation evidence;
- effectiveness test and result;
- residual risk and expiry/review date; and
- change or incident triggers that reopen the decision.

An equivalent control must achieve the same risk objective in the actual context. Deferral must state the proof gap, interim control, owner, due date, and exposure accepted. Not-applicable decisions must not be used to avoid a material but difficult-to-measure risk.

5. Define release and operating gates

Before deployment or material expansion, require evidence that:

- intended and foreseeable uses are documented;
- relevant risk families were assessed;
- required tests met approved thresholds;
- critical and high findings are resolved or explicitly rejected by authorized risk acceptance;
- human oversight is competent, available, and effective;
- supplier and component risks are within tolerance;
- content provenance and disclosure controls are fit for purpose;
- monitoring, incident disclosure, stop, rollback, and fallback controls are operational;
- users and downstream actors receive necessary limitations and instructions; and
- residual risk is approved by the correct authority.

Stop or rollback triggers should include threshold breach, new dangerous capability, control failure, material privacy/security event, repeated harmful output, unreliable oversight, supplier loss, unexplained drift, serious incident, or evidence that actual use differs materially from the approved context.

6. Preserve the evidence and decision loop

Manual 04 memory graphic 3

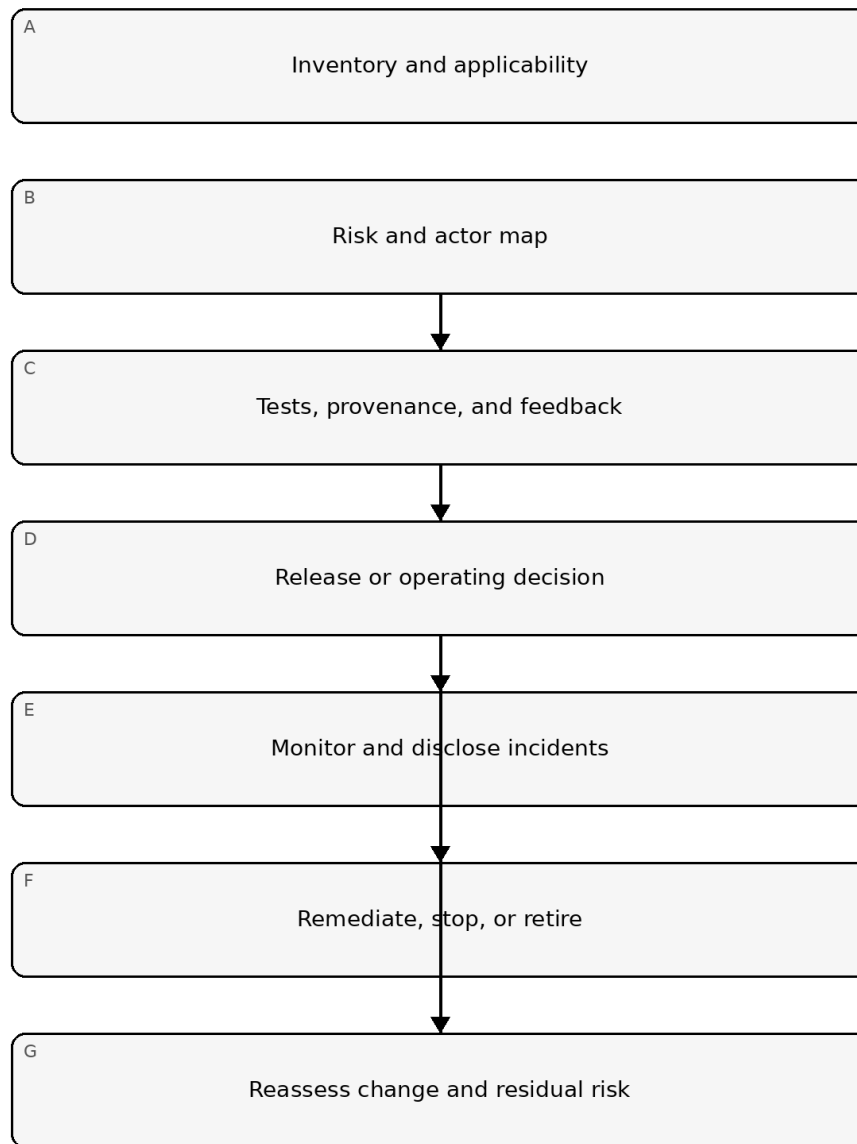


Figure 3. Implementation memory graphic

Accessible explanation: The evidence loop begins with inventory and applicability, then maps risks and actors, collects tests and feedback, and reaches an accountable decision. Approved or conditional use is monitored; rejected use is remediated, stopped, or retired. Change and residual-risk reassessment restart the loop.

7. Analyst and manager completion criteria

An analyst should be able to show:

- the exact NIST source and controlled version used;
- the relevant model/system/use-case/ecosystem boundaries;
- every risk-family disposition;
- action applicability and tailoring evidence;

- source-to-control-to-test-to-decision traceability;
- open assumptions, limitations, and proof gaps; and
- monitoring, incident, and reassessment records.

A manager should be able to answer:

- who owns the risk and who can approve, stop, or rollback the system;
- which harms or failures exceed tolerance;
- which evidence supports the decision and what remains uncertain;
- whether human oversight and supplier controls work in practice;
- how affected parties and downstream actors are protected and informed;
- what changes invalidate the approval; and
- whether residual risk is still acceptable.

Assurance statement

This implementation intake supports controlled, evidence-based use of NIST AI 600-1. It does not certify a system, replace applicable law or contract, prove that every suggested action applies, establish legal compliance, or provide an audit opinion. Human reviewers and authorized decision-makers remain accountable for applicability, semantics, risk acceptance, and release.

Controlled 32-chapter manual

Chapter 01 — Purpose, scope, and applicability

This manual operationalizes generative-AI risk management for organizations that design, acquire, integrate, deploy, operate, or retire generative-AI capabilities. The implementation boundary is deliberately risk-based: not every control, test, evidence item, or operating practice applies to every use case.

Each implementation begins with a documented applicability decision covering the use case, affected parties, deployment context, data handled, autonomy, external dependencies, and the consequences of error or misuse. The applicability record becomes controlled evidence and must be revisited when the system, model, data, tooling, supplier, or operating context materially changes.

Minimum evidence:

- use-case description and business owner;
- system/model/component inventory reference;
- affected-party and stakeholder identification;
- risk-tier or equivalent classification;
- applicability rationale;
- reviewer and approval date.

Chapter 02 — Relationship to AI RMF 1.0

NIST AI 600-1 is treated as a generative-AI profile and companion to the AI RMF rather than as a stand-alone universal checklist. The operating model therefore retains GOVERN, MAP, MEASURE, and MANAGE as the management cycle while adding generative-AI-specific risk families, testing expectations, provenance considerations, and incident signals.

Organizations should map each GAI implementation decision to the relevant AI RMF function and preserve traceability from risk statement to evidence, decision, action, and residual risk.

Required control behavior:

- GOVERN sets policy, accountability, authority, and escalation;
- MAP defines context, use, actors, dependencies, and plausible harms;
- MEASURE evaluates performance, safety, security, privacy, integrity, and uncertainty;
- MANAGE selects treatments, accepts residual risk, monitors operation, and triggers stop/rollback when thresholds are exceeded.

Chapter 03 — Implementation paths

Three proportional paths are supported.

Essential

For lower-complexity or lower-impact uses. Requires inventory, ownership, basic risk screening, minimum testing, human oversight, incident handling, and documented approval.

Structured

For material business, customer, workforce, security, privacy, financial, or operational use. Requires formal risk registers, evidence matrices, test plans, supplier review, change controls, monitoring thresholds, incident playbooks, and periodic reassessment.

Enhanced

For high-impact, high-autonomy, safety-sensitive, regulated, externally exposed, or otherwise consequential uses. Requires independent challenge, deeper adversarial testing, formal release criteria, stronger provenance, explicit stop/rollback authority, enhanced monitoring, and documented residual-risk acceptance by accountable management.

Implementation path selection must be justified and may only be downgraded through documented approval.

Chapter 04 — Governance and accountability

Every GAI system must have named business, technical, security, privacy/data, and risk owners appropriate to its scope. Accountability cannot be delegated solely to a model provider or implementation vendor.

Governance should define:

- who may approve a new use case;
- who may approve model, prompt, retrieval, tool, or data changes;
- who owns testing and evidence;
- who can suspend or roll back deployment;
- who accepts residual risk;
- who receives incident notifications;
- who conducts periodic review.

Conflicts of interest should be identified where the same person designs, tests, and approves a high-impact system. Enhanced implementations should add independent review or challenge.

Chapter 05 — Inventory and system decomposition

Treat the GAI capability as a system, not merely a model. The inventory should identify the model, hosting environment, retrieval layer, vector store, prompts/system instructions, tools, APIs, data sources, fine-tuning artifacts, guardrails, monitoring components, external services, and human decision points.

The inventory should capture version, owner, supplier, deployment location, data classification, authentication boundary, change authority, and retirement status. Dependencies that can materially alter output or behavior must be separately traceable.

A system change is material when it can alter risk, capability, exposure, output quality, safety, security, privacy, compliance posture, or affected-party impact.

Chapter 06 — GAI risk-family model

The controlled Manual 04 baseline preserves twelve generative-AI risk families:

1. CBRN Information or Capabilities
2. Confabulation
3. Dangerous, Violent, or Hateful Content
4. Data Privacy
5. Environmental Impacts
6. Harmful Bias and Homogenization
7. Human-AI Configuration
8. Information Integrity
9. Information Security
10. Intellectual Property
11. Obscene, Degrading, and/or Abusive Content
12. Value Chain and Component Integration

These risk families are screening categories, not automatic findings. Each use case must determine which families are applicable, the credible scenarios involved, existing controls, evidence, residual risk, and monitoring indicators.

Chapter 07 — Risk statements and impact pathways

Risk records should be scenario-based rather than generic. A useful structure is:

Condition or threat → system behavior → affected asset/person/process → consequence → control/evidence → residual risk.

For example, a retrieval-enabled assistant may ingest untrusted content, follow malicious embedded instructions, invoke an external tool, and expose restricted information. The risk statement should describe the complete pathway rather than only labeling the issue “prompt injection.”

Impact analysis should consider direct, indirect, cumulative, and foreseeable misuse effects. Where impacts are uncertain, uncertainty must be recorded rather than silently converted into a low-risk conclusion.

Chapter 08 — Release authority and fail-closed gates

No GAI use case should move to production merely because automated tests pass. Release requires documented evidence sufficient for the selected implementation path, unresolved exceptions within approved tolerance, responsible-owner sign-off, and any required human review.

A release gate must fail closed when:

- required evidence is missing or stale;
- mandatory testing is incomplete or failed;
- critical findings remain open without approved treatment;
- a required human review is missing, rejected, or invalidated by material change;
- legal, security, privacy, safety, or operational applicability is unresolved;
- rollback/stop capability is required but not validated.

Material change after approval reopens the affected review and release gates.

Chapter 09 — Confabulation and output reliability

Confabulation risk is managed through use-case-specific evaluation rather than a single accuracy percentage. Teams should identify statements that must be factual, the acceptable error rate, the consequences of false confidence, and the controls used when the model lacks reliable support.

Useful controls include retrieval-grounding, source display, constrained generation, abstention behavior, human validation, deterministic downstream checks, and restrictions on high-consequence autonomous actions.

Evidence should include evaluation datasets, acceptance thresholds, observed failure modes, representative examples, remediation decisions, and residual-risk approval.

Chapter 10 — Harmful, abusive, and dangerous content

Organizations should define categories of content that are prohibited, restricted, context-dependent, or acceptable for the specific use case. Policy must distinguish user-input handling from model-output handling and should address adversarial attempts to bypass safeguards.

Testing should include expected use, misuse, boundary conditions, prompt manipulation, multilingual variation where relevant, and escalation behavior. A refusal mechanism that can be trivially bypassed should not be treated as an effective control.

Chapter 11 — Data privacy and sensitive information

Privacy review should trace data across prompts, retrieval stores, logs, training or fine-tuning pipelines, external APIs, observability platforms, support channels, and retained conversation history.

The minimum control set should address data minimization, purpose limitation, access, retention, deletion, redaction, secrets handling, logging, third-party processing, and user disclosure where applicable.

Testing should intentionally look for memorization, data leakage, retrieval overexposure, cross-user contamination, and unauthorized disclosure through tools or connectors.

Chapter 12 — Harmful bias, homogenization, and human impact

Bias evaluation should be tied to the decisions, recommendations, classifications, content, or experiences produced by the system. Teams should identify populations or stakeholder groups that could experience different failure rates or harms.

Controls may include dataset analysis, outcome testing, subgroup evaluation, human escalation, alternative workflows, monitoring, and restrictions on the use of generated content in consequential decisions.

Where measurement is limited by data or sample size, that uncertainty should be documented rather than represented as evidence of fairness.

Chapter 13 — Human-AI configuration and oversight

Human oversight must be designed, not assumed. The organization should determine what the human is expected to notice, what evidence is available, whether there is enough time and authority to intervene, and how automation bias will be reduced.

For consequential uses, define:

- decisions the system may make or recommend;
- decisions reserved for humans;
- escalation triggers;
- override authority;
- logging of human review;
- competency requirements;
- fallback procedures when the system is unavailable or unreliable.

Chapter 14 — Information integrity and provenance

Information-integrity controls should help users distinguish generated, retrieved, transformed, and authoritative information. Provenance should be preserved where it materially affects trust, review, attribution, or downstream use.

Depending on the system, evidence may include source references, content metadata, signed artifacts, transformation history, prompt/version identifiers, model/version records, and traceability from output to supporting material.

Provenance claims must be bounded: metadata or labels improve traceability but do not by themselves prove truth or authenticity.

Chapter 15 — Information security and adversarial testing

GAI security testing should cover the full system attack surface: prompts, retrieval sources, vector databases, model endpoints, plugins/tools, identities, secrets, APIs, user interfaces, logs, orchestration layers, and supplier integrations.

Testing should include prompt injection, indirect prompt injection, unauthorized tool use, privilege escalation, sensitive-data extraction, malicious retrieval content, model or system prompt disclosure, abuse of external actions, and denial or degradation scenarios where relevant.

Findings should be linked to concrete controls, owners, remediation, retest evidence, and residual-risk decisions.

Chapter 16 — Intellectual property, value chain, and component integration

The organization should identify licensed, proprietary, third-party, open-source, and externally hosted components that influence the system. Supplier terms, usage restrictions, output rights, data-processing terms, and component dependencies should be documented where relevant.

Value-chain review should include model providers, hosting platforms, datasets, retrieval sources, plugins, APIs, safety services, monitoring providers, and subprocessors. A supplier questionnaire alone is not sufficient evidence for high-risk dependencies.

Material supplier or component change should trigger reassessment when it can alter capability, data handling, contractual exposure, security posture, availability, or output behavior.

Chapter 17 — Evaluation strategy

Evaluation begins with a documented question: what must the system be able to do, what must it avoid doing, under what conditions, and with what confidence? The evaluation strategy should define objectives, scenarios, datasets, evaluators, methods, thresholds, sampling, limitations, and decision rules.

Evaluation should include representative normal use and plausible misuse. High-impact systems should use independent challenge or separation between builders and final release decision-makers.

Chapter 18 — Test data and scenario governance

Test data should be traceable to purpose. Teams should record origin, coverage, sensitivity, transformation, representativeness, known limitations, and whether the data may be retained or shared.

Synthetic test data can improve coverage but should not be assumed to represent real-world populations or adversarial behavior. Where synthetic data is used, the evaluation record should state why it is appropriate and what blind spots remain.

Chapter 19 — Acceptance thresholds and decision criteria

Thresholds should be set before final release testing where practical. They should reflect consequences, not convenience. A low-impact drafting assistant may tolerate different failure rates than a system influencing security, finance, health, employment, or safety decisions.

A release decision should record whether each threshold passed, failed, was conditionally accepted, or was waived. Waivers require rationale, owner, compensating control, expiration or review date, and residual-risk approval.

Chapter 20 — Red teaming and adversarial evaluation

Adversarial evaluation should test whether controls remain effective when users or external content intentionally attempt to bypass them. Test cases should address direct prompt manipulation, indirect instructions, retrieval poisoning, tool abuse, identity or permission boundary failures, data extraction, system prompt disclosure, and unsafe action chaining when applicable.

Red-team results should be treated as evidence, not theater. Repeated tests with no remediation ownership or retesting should not be represented as assurance.

Chapter 21 — Content provenance controls

Provenance should support practical questions: what model and configuration produced this output, what data or sources materially influenced it, what transformations occurred, and who or what approved subsequent use?

The organization should select provenance mechanisms proportional to risk. These may include source links, artifact hashes, model/version identifiers, prompt or policy versions, transformation logs, human approval records, or signed metadata.

Provenance improves traceability but does not prove factual accuracy or lawful origin by itself.

Chapter 22 — Pre-deployment testing package

A pre-deployment evidence package should assemble the material needed for an accountable release decision. At minimum it should include:

- system/use-case inventory record;
- risk and impact register;
- evaluation plan and results;
- security/adversarial test results;
- privacy/data review where applicable;
- supplier/component evidence;
- unresolved findings and exceptions;
- monitoring thresholds;
- rollback/stop plan;
- approval record.

The package should be versioned and linked to the exact release candidate.

Chapter 23 — Incident disclosure and escalation readiness

Before deployment, the organization should define what events qualify as a GAI incident, who must be informed, what evidence must be preserved, and when external notification or disclosure may be required.

Incident categories can include harmful output, data exposure, unauthorized action, control bypass, supplier failure, material misinformation, unexpected autonomy, regulatory or contractual breach, or repeated threshold violation.

Escalation criteria should be explicit enough that operators are not forced to invent severity rules during an event.

Chapter 24 — Evidence sufficiency and review quality

Evidence should demonstrate that a control operated for the relevant system and period. Policies, screenshots, vendor claims, or questionnaires may support evidence but should not automatically be treated as proof of effectiveness.

Reviewers should consider relevance, reliability, completeness, timeliness, and independence of evidence. When evidence is weak or unavailable, the record should state that limitation and the resulting effect on residual risk or release confidence.

Chapter 25 — Deployment and release controls

Deployment should use a controlled release record tied to the tested artifact, configuration, model version, data/retrieval state, tools, guardrails, and approved operating conditions. Material deviation between the tested candidate and deployed system invalidates the release evidence until assessed.

Release records should identify accountable approvers, open exceptions, monitoring thresholds, rollback authority, and review dates.

Chapter 26 — Monitoring and operating thresholds

Monitoring should be tied to known risks and decision thresholds rather than generic telemetry. Relevant measures may include harmful-output rates, unsupported-answer rates, security events, data leakage signals, user complaints, tool failures, model drift indicators, latency/availability, supplier changes, and exception volume.

Threshold breaches should map to predefined actions: investigate, restrict, increase human review, disable a function, roll back, or stop the system.

Chapter 27 — Change management and reassessment

Changes to models, prompts, system instructions, retrieval sources, tools, permissions, data handling, suppliers, guardrails, interfaces, or business use can alter risk. Change records should classify materiality and identify which prior evidence remains valid.

Material changes reopen the affected risk, test, security, privacy, accessibility, human-review, and release gates. Emergency changes require retrospective review and evidence completion within a defined period.

Chapter 28 — Incident response and containment

GAI incident response should integrate with enterprise incident management while preserving AI-specific evidence. Teams should capture prompts, outputs, model/configuration identifiers, retrieval context, tool calls, identities, timestamps, logs, affected records, supplier notices, and control state where lawful and feasible.

Containment options can include disabling tools, reducing permissions, isolating retrieval sources, reverting configuration, limiting users, increasing human review, or suspending the service.

Chapter 29 — Corrective action and remediation validation

Corrective action should address root causes rather than only suppressing the observed output. Remediation records should identify the finding, cause, owner, planned action, due date, validation method, evidence, residual risk, and closure decision.

A fix should not be considered closed solely because one test case now passes. Retesting should assess likely variants and regression risk.

Chapter 30 — Periodic review and management reporting

Periodic review should evaluate whether the use case remains appropriate, controls remain effective, risk assumptions remain valid, evidence is current, suppliers or components have changed, and operating results remain within tolerance.

Management reporting should distinguish facts, trends, assumptions, unresolved risks, accepted exceptions, and decisions required. High-risk issues should be visible to the accountable risk owner rather than buried in technical reporting.

Chapter 31 — Retirement, data disposition, and exit

Retirement planning should address model endpoints, credentials, prompts, retrieval indexes, vector stores, logs, user data, caches, integrations, vendor access, retained evidence, and contractual obligations.

The organization should verify data return or deletion where required, revoke access and secrets, disable integrations, preserve required records, document unresolved obligations, and record the retirement decision.

Chapter 32 — Assurance, limitations, and final release boundary

Assurance is cumulative and scope-specific. Repository QA, automated testing, red teaming, documentation, or a completed checklist does not guarantee that a GAI system is safe, secure, compliant, accurate, fair, or fit for every context.

Before publication of this manual itself, the controlled package must complete source verification, technical/editorial review, es-419 and pt-BR semantic review, graphics/accessibility verification, DOCX/PDF generation, page-level QA, provenance and checksums, repository/security review, and explicit Final Human Release Approval.

Any material content change after human approval reopens the affected review gate.